

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (NVD-sourced CVE lookup + Maven) · Generated 2026-07-06 · Source: `pom.xml`

Summary

Metric	Count
Dependencies scanned	24 (23 resolved + 1 unresolvable typosquat)
Total CVE findings (dependency×CVE pairs)	77
CRITICAL CVE findings	18
HIGH CVE findings	43
MEDIUM CVE findings	15
LOW CVE findings	1
Outdated dependencies	8 (6 safe patch/minor, 2 major-review)
License violations	2
Supply-chain alerts	2

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.26.1
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2021-44228	10.0	CRITICAL	2.26.1
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379 (+ 49 more)	9.8	CRITICAL	2.13.4.2
com.google.protobuf:protobuf-java (transitive)	3.19.4	CVE-2024-7254	7.5	HIGH	3.25.5
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	5.5	MEDIUM	32.0.0-jre
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.14.0
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0
mysql:mysql-connector-java	8.0.30	— (GPL-2.0 license violation)	—	MEDIUM	8.0.33

Notable CVEs

CVE	Dependency	CVSS	Severity
CVE-2021-44228	log4j-core / log4j-api	10.0	CRITICAL
CVE-2021-45046	log4j-core / log4j-api	9.0	CRITICAL
CVE-2026-34479/80/81	log4j-core / log4j-api	7.5	HIGH
CVE-2019-14379 (+13 more CRITICAL)	jackson-databind	9.8	CRITICAL
CVE-2022-3509 / CVE-2022-3510 / CVE-2024-7254	protobuf-java (transitive)	7.5	HIGH

CVE-2023-2976	guava	5.5	MEDIUM
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2021-29425	commons-io	4.8	MEDIUM

Outdated dependencies

Dependency	Current	Latest	Update type
log4j-core / log4j-api	2.14.1	2.26.1	minor
jackson-databind	2.9.8	2.22.0	minor
guava	24.1.1-jre	33.6.0-jre	major
commons-io	2.4	2.22.0	minor
commons-lang3	3.4	3.20.0	minor
mysql-connector-java	8.0.30	8.0.33	patch
junit-jupiter (test)	5.10.2	6.1.1	major

License findings

Dependency	License	Status
mysql:mysql-connector-java	GPL-2.0-with-FOSS-exception	VIOLATION
com.fastxml.jackson.core:jackson-databind (typosquat)	Unknown (unresolvable)	VIOLATION
All other resolved dependencies	Apache-2.0 / MIT / BSD-3-Clause / EPL-2.0	OK

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core` ; the coordinate does not exist on Maven Central and fails resolution (`mvn dependency:tree` errors trying to fetch its POM). **Remove immediately.**

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP, non-allowlisted Maven repository declared in `pom.xml` . Confirmed blocked by the build environment's default mirror during dependency resolution (MITM artifact-injection risk). Remove or replace with an HTTPS allowlisted mirror.